THREAT ADVISORY

Node.js

High-Severity RCE Flaw Found in Brotli Decoder

Node.js released security updates on 21 October 2026 to address **CVE-2026-111497**, a High-severity vulnerability in its bundled Brotli decoder. Specially crafted compressed data can trigger memory corruption and potentially lead to remote code execution. The flaw affects unpatched **22.x, 24.x, and 26.x** runtimes. Administrators are urged to update immediately and review applications that process untrusted Brotli data.

Sources: **Node.js · Vercel** · 22 Oct 2026
CVE-2026-111497 · High Severity · Node.js 22.x / 24.x / 26.x

THREAT ADVISORY

Where Brotli creates exposure in Node.js

CVE-2026-111497 / BUNDLED BROTLI DECODER

KEY TAKEAWAYS

Node.js patched a **High-severity** Brotli decoder flaw on **21 October 2026** that could corrupt memory and permit remote code execution.

Exposure requires attacker-controlled Brotli data to reach the decoder, through incoming requests or fetched responses.

Update affected **22.x, 24.x and 26.x** runtimes; WAF protection does not replace patching.

The reviewed vendor advisories do not report confirmed exploitation in the wild as of **22 October 2026**.

HIGH

SEVERITY

10 VULNERABILITIES ADDRESSED

This coordinated release also fixes nine other issues. The Brotli flaw is one part of the security update.

Node.js credits OpenAI Codex Security researchers **Khai Tran and Sylvie Mayer** with reporting this vulnerability.

TECHNICAL DETAILS

Why the decoder overruns its buffer

Public Brotli analysis describes repeated dictionary operations that produce **no output** but still consume the distance-block counter. The counter can reach zero while decoding the same output block.

The next block-switch failure is misclassified as **NEEDS_MORE_INPUT**. The streaming retry loop keeps appending bytes to an **8-byte internal buffer** because it assumes more input will let decoding continue.

The structural error persists. Writes pass the buffer boundary and overwrite adjacent decoder state; corrupted position and distance fields can then lead to further out-of-bounds writes.

DECODER FAILURE SEQUENCE

01 / INVALID STATE

Counter exhausted; invalid block switch

→

02 / WRONG RESULT

Error treated as missing input

→

03 / MEMORY DAMAGE

Retry exceeds the 8-byte buffer

The upstream fix distinguishes invalid-stream errors from genuine input shortages and rejects the malformed block switch earlier.

Source scope: Mozilla Bug 2029458 analyses the shared Brotli decoder in Firefox. Its browser findings are not direct proof of Node.js exploitation; Node.js release notes separately confirm the corresponding Brotli correction.

APPLICATION EXPOSURE

How applications reach the decoder

The following paths illustrate how untrusted Brotli content can reach an affected runtime. Reachability depends on library versions, configuration and application behaviour.

01 / FETCHED RESPONSES – fetch()

A server-side fetch can receive **Content-Encoding: br** from an attacker-controlled service. Response decompression can reach Brotli even when public endpoints reject compressed request bodies.

02 / INCOMING REQUESTS – body-parser

Brotli-capable versions can decode **br** request bodies with **inflate: true**, the default. Requests must reach a matching parser; Express use alone does not establish exposure.

03 / DIRECT DECOMPRESSION – node:zlib

Code or dependencies can pass untrusted data to **brotliDecompress()** or **createBrotliDecompress()**. Reviewing only direct application calls can miss decoding performed by dependencies.

Exposure condition: attacker-controlled Brotli data must be processed by a vulnerable decoder. These paths are examples to review, not confirmed exploitation of every application using these APIs.

AFFECTED VERSIONS & FIXES

Patched runtimes and verification

These security releases include the Brotli fix. Use the applicable release or a later patched version in the same line.

RELEASE LINE	UPDATE IF EARLIER THAN	FIXED RELEASE
22.x	22.23.4	**22.23.4**
24.x	24.22.1	**24.22.1**
26.x	26.12.1	**26.12.1**

Migrate end-of-life runtimes to a supported, patched line. An older branch without a security release should not be assumed unaffected.

Google also released Brotli **1.0.10, 1.1.1 and 1.2.1**. These are library versions; Node.js deployments need a fixed runtime or a distribution build with a documented backport.

CHECK THE DEPLOYED RUNTIME

```
node --version
```

Check inside the deployed container or service environment using its Node.js binary. Restart or replace affected processes and verify the application's runtime; an administrator's shell may resolve a different installation.

EXPLOITATION EVIDENCE

What the demonstrations establish

Vercel reports memory disclosure and command execution on unpatched Node.js **22.x, 24.x and 26.x**. This is separate from the public PoC repository's own findings.

PUBLIC PoC / STOCK NODE.JS

Node.js v24.9.0

The author reports a Windows crash and limited Linux memory disclosure. Portable command execution on arbitrary Node.js processes was not established.

PUBLIC PoC / SPECIAL HARNESS

Local, non-PIE Brotli harness

The author reports command execution in a deliberately configured native test program, not a standard Node.js deployment.

Patched **Node.js 24.22.1** rejected the stream in the author's tests. These results were **not independently reproduced** for this assessment.

EXPLOITABILITY AND CAMPAIGN EVIDENCE

As of **22 October 2026**, the reviewed vendor advisories do not report confirmed exploitation in the wild. Research demonstrations alone do not establish an active campaign.

Potential impact: execution inherits the Node.js process's permissions. Accessible credentials, application data and operations could be affected, depending on service isolation.

REMEDIATION & INVESTIGATION

Patch, verify and investigate

UPDATE THE RUNTIME

Update external backends, self-hosted applications, CI runners and local environments. Rebuild containers with patched base images and redeploy. Verify managed-runtime rollout status before assuming a hosted service is fixed.

IF PATCHING IS DELAYED

Temporarily disable processing of untrusted Brotli content where feasible, including dependency and external-response paths. Vercel's WAF protects inbound traffic through its network, **not responses fetched from other servers**; it does not replace patching.

INVESTIGATION LEADS / NOT VALIDATED SIGNATURES

- Native crashes or repeated errors during Brotli decoding.
- Unusual compressed inputs associated with those events.
- Unexpected child processes or outbound connections afterwards.

The reviewed vendor advisories provide no campaign-specific IP, domain or file-hash IOC list. These general leads can have benign causes and do not independently prove exploitation.

Preserve application logs, crash records and request or response metadata where available; correlate them with process activity. **Patching does not establish whether compromise occurred beforehand.**

Stay vigilant. **Follow Memori CTI for more threat intel.**